SOFTWARE CHANGE IMPLEMENTATION REPORT

CR-026: Email OTP Password Reset

Field	Details
Change Request ID	CR-026
Change Request Title	Email OTP Password Reset
Student Name	M M Amal
Student ID	JF/ICT/24/15
Implementation Status	Completed
Date	15 October 2026

1. Change Request Summary

1.1 Business Requirement

Users need a secure way to recover access to their Student Management System account if they forget their password. The system should allow a user to request a one-time password (OTP) using their registered email address and then set a new password after the OTP is verified.

The recovery process should validate the user's details, use a time-limited OTP, and securely store the new password.

1.2 Existing Behaviour

Before implementation, the login page did not provide an email-based password recovery process. A user who forgot their password could not request an OTP through the application and reset their password using their registered email address.

1.3 Requested Change

CR-026 requested an email OTP-based password reset feature that:

- Allows a user to request an OTP using their registered email address.
- Sends a six-digit OTP to that email address.
- Allows the user to enter the OTP and choose a new password.
- Rejects an invalid, expired or already-used OTP.
- Expires the OTP after 10 minutes.
- Allows an OTP to be used only once.
- Validates the new password and its confirmation.
- Stores the new password securely as a bcrypt hash.
- Provides suitable success or error messages during the recovery process.

2. Implementation

2.1 Implementation Summary

The password recovery feature was added to the Student Management System login flow. A **Forgot Password?** link was added to the login page. It opens a form where the user enters their registered email address and requests an OTP.

After the OTP request is processed, the application displays a confirmation message and provides a button to continue to the password reset form. On that form, the user enters their email address, the six-digit OTP, a new password and confirmation of the new password.

The backend generates and emails the OTP, validates it when the user submits the reset form, and updates the account password after successful verification. OTP records are stored in the database with their expiry time, attempt count and usage status.

2.2 Affected Files

File	Change	Purpose
frontend/src/components/LoginFormSection.jsx	Modified	Adds the **Forgot Password?** link to the login form.
frontend/src/pages/ForgotPasswordPage.jsx	Added	Provides the form for submitting a registered email address and requesting an OTP.
frontend/src/pages/ResetPasswordPage.jsx	Added	Provides the form for entering the OTP and setting a new password.
frontend/src/styles/passwordRecovery.css	Added	Styles the password recovery pages and controls.
frontend/src/routes/AppRoutes.jsx	Modified	Registers the Forgot Password and Reset Password pages.
frontend/src/services/authService.js	Modified	Sends password recovery and password reset requests to the backend API.
backend/src/routes/authRoutes.js	Modified	Registers the forgot-password and reset-password API endpoints.
backend/src/controllers/authController.js	Modified	Handles OTP requests, email delivery, input validation and password reset requests.
backend/src/models/userModel.js	Modified	Creates OTP records, validates OTPs, and updates the password in the database.
backend/src/utils/emailService.js	Added or modified	Sends the password reset OTP email using the configured SMTP service.
database/migrations/CR-026_email_otp_password_reset.sql	Added	Adds email and password reset OTP database support.

2.3 Technical Changes

Frontend
The login form now provides a link to the Forgot Password page. The email recovery form validates the email address before submitting the request. After the request is submitted, the page displays a confirmation message and provides a button to proceed to the Reset Password page.
The reset form accepts the registered email address, a six-digit OTP, a new password and confirmation of the new password. It checks that the email is valid, the OTP contains six digits, the new password is at least eight characters long and the password fields match.

Backend API and Validation
The backend provides the following public authentication endpoints:

- POST /api/auth/forgot-password — processes a password recovery request and sends an OTP when an account is associated with the submitted email address.
- POST /api/auth/reset-password — verifies the submitted OTP and updates the password after successful validation.

The backend normalizes email addresses and independently validates the submitted values. The forgot-password endpoint returns a general response so that the response does not disclose whether an email address is registered to an account.

OTP Generation and Email Delivery
For a matching account, the backend generates a six-digit OTP and sends it to the registered email address using the configured SMTP service. The email states that the OTP expires after 10 minutes and can only be used once.
The OTP is hashed before it is stored in the database. The application needs valid SMTP settings in its backend environment to send recovery emails.

Password Storage
The backend hashes the new password with bcrypt before updating the user account. Plain-text passwords are not stored in the database.

Database Changes
The migration adds an email column to the users table if it does not already exist. It copies student email addresses to linked user accounts where the migration can do so without an email conflict.
The migration also creates a password_reset_otps table. It stores each OTP hash, its user account, expiry time, verification attempts, usage status and creation time. Administrator accounts need an email address registered before they can use email-based password recovery.

2.4 Implementation Logic

- The user opens the login page and selects **Forgot Password?**.
- The user enters their registered email address and submits the OTP request.
- The frontend validates the email format and sends the request to POST /api/auth/forgot-password.
- The backend normalizes and validates the email address and looks up the matching account.
- If an account is found, the backend generates a six-digit OTP, hashes it, invalidates earlier unused OTPs for that account and stores a new OTP record.
- The backend sends the OTP email using the configured SMTP service.
- The application displays a confirmation message and allows the user to continue to the reset form.
- The user submits their email address, OTP, new password and password confirmation.
- The backend validates the submitted values and checks that the OTP is valid, has not expired, has not already been used and has not exceeded the allowed number of attempts.
- When validation succeeds, the backend hashes the new password and updates the user account.
- The OTP is marked as used, and any other active OTPs for that account are invalidated.
- The frontend displays a successful reset message. The user can return to the login page and log in with the new password.

2.5 Error and Data Handling

The frontend checks the email address, OTP format, password length and password confirmation before submitting the reset request. The backend repeats the relevant validation before processing the request.

The application rejects a reset request if:

- The email address is invalid or required values are missing.
- The OTP is not six digits.
- The OTP is invalid, expired or already used.
- The OTP has exceeded the allowed verification attempts.
- The new password is shorter than eight characters.
- The new password and confirmation do not match.

If the email service cannot send the OTP, the backend returns an error response asking the user to try again later. Unexpected errors are handled by the backend and are not reported as successful resets. After a successful reset, the frontend displays a confirmation message and clears the OTP and password fields.

3. Testing & Verification

3.1 Testing Approach

Field	Details
Testing Types	Functional, validation, authorization, and regression testing
Environment	Development environment
Testing Method	Manual testing
Testing Status	Completed

3.2 Test Cases

No.	Test case	Expected result	Result
1	Open the Forgot Password page from the login page	The Forgot Password page opens	Pass
2	Submit a valid registered email address	The application processes the request and displays a confirmation message	Pass
3	Request an OTP for an account with an email address	The OTP email is sent to the registered email address	Pass
4	Enter a valid OTP and matching new passwords	The password is reset successfully	Pass
5	Log in with the newly set password	Login succeeds	Pass
6	Submit an invalid email address	The application rejects the email and displays a validation message	Pass
7	Submit an invalid, expired or already-used OTP	The application rejects the reset request and does not update the password	Pass
8	Submit a password shorter than eight characters	The application rejects the password	Pass
9	Submit passwords that do not match	The application displays a password mismatch message	Pass
10	Request a new OTP after an earlier OTP was issued	The earlier unused OTP is invalidated	Pass

3.3 Test Summary

Test Result	Count
Total Test Cases	**10**
Passed	**10**
Failed	**0**
Pass Rate	**100%**

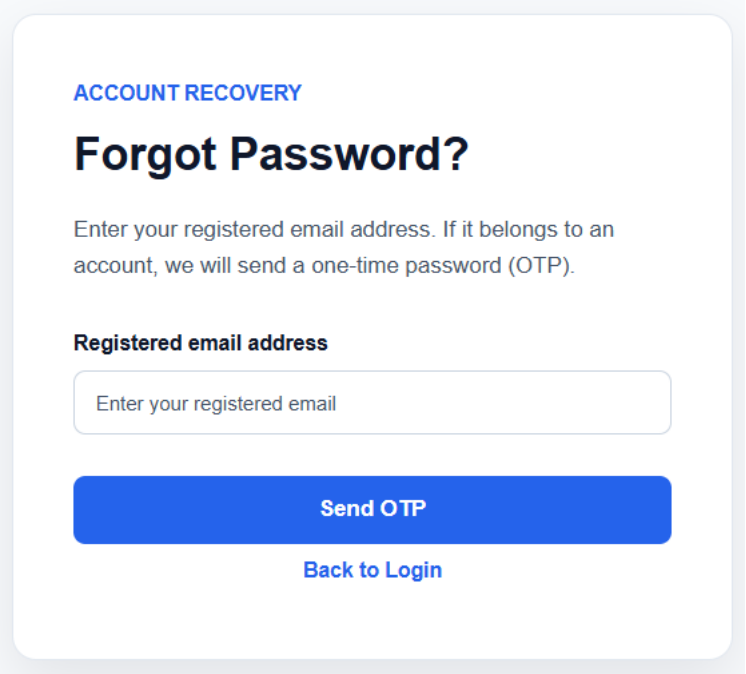
Overall Test Result: Pass

4. Acceptance Criteria Verification

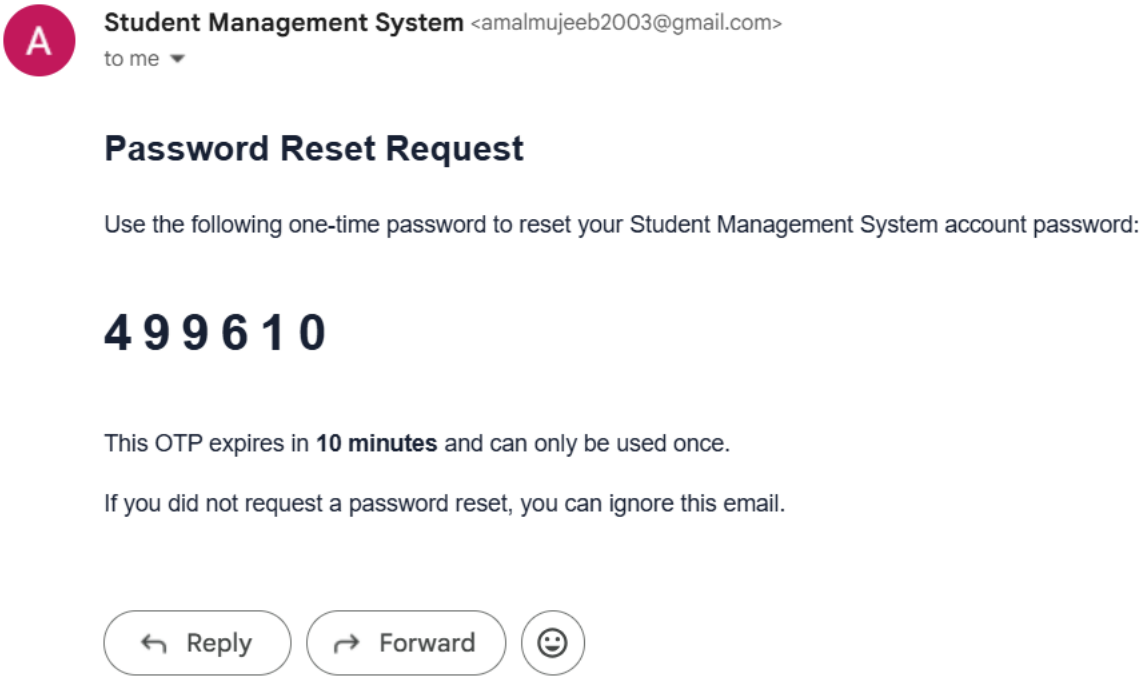
No.	Acceptance criterion	Verification method	Result
1	A user can open the password recovery process from the login page	Open the login page and select Forgot Password?	Pass
2	A user can request an OTP using their registered email address	Submit the registered email address and verify the confirmation and email delivery	Pass
3	The OTP expires after 10 minutes and is single-use	Verify an OTP reset and reject reuse or expired OTPs	Pass
4	The application validates the OTP and password details before changing the password	Submit valid and invalid OTP and password details	Pass
5	The new password is stored securely as a bcrypt hash	Verify the implemented password hashing and successful login with the new password	Pass
6	The user can log in after a successful password reset	Return to login and sign in using the new password	Pass

5. Evidence

Evidence 01 – Forgot Password Page



Evidence 02 – OTP Email Received



Student Management System <amalmujeeb2003@gmail.com>
to me

Password Reset Request

Use the following one-time password to reset your Student Management System account password:

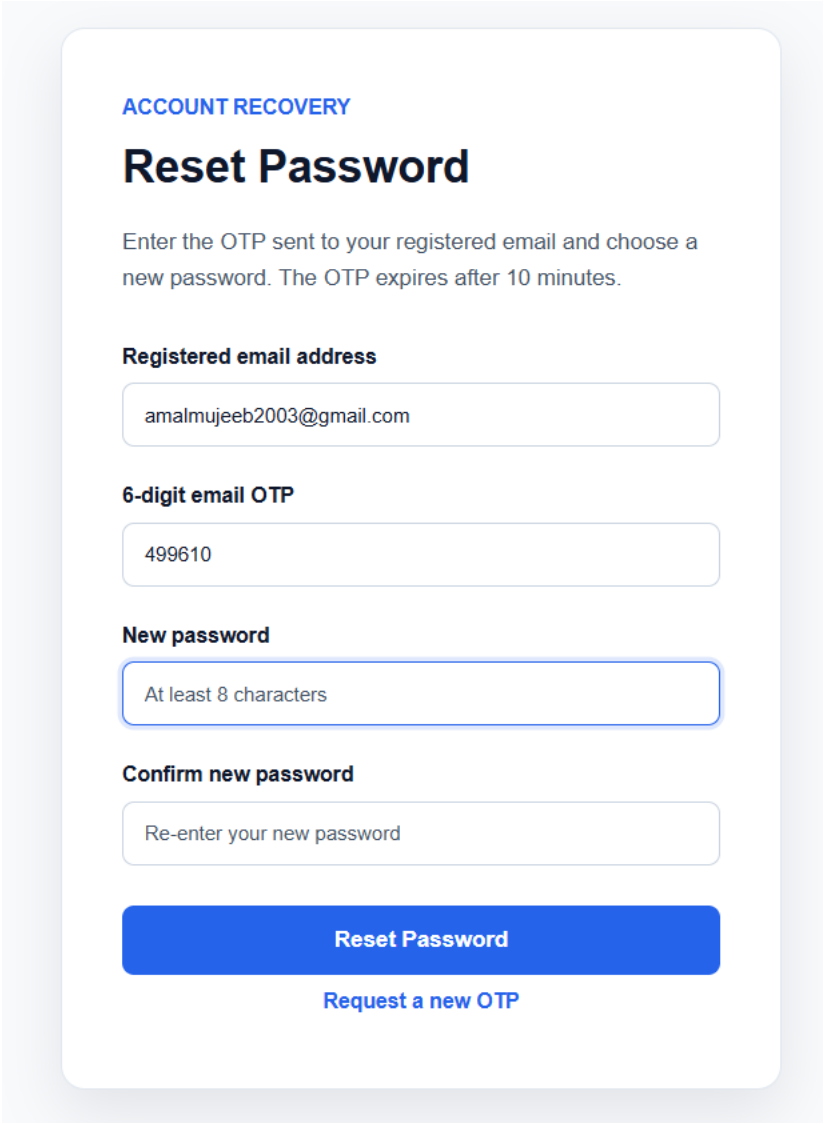
4 9 9 6 1 0

This OTP expires in **10 minutes** and can only be used once.

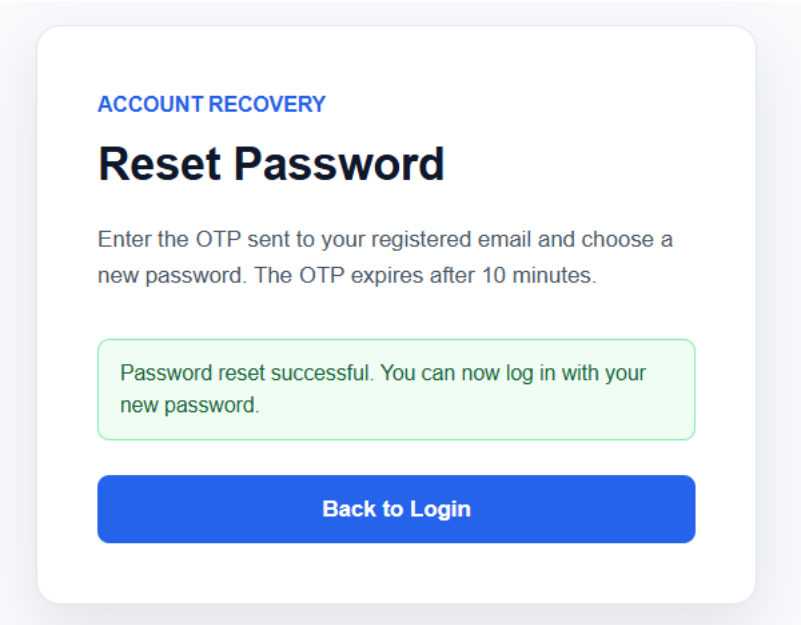
If you did not request a password reset, you can ignore this email.

Reply Forward

Evidence 03 – OTP Verification Page



Evidence 04 – Successful Password Reset



6. Final Result

Item	Result
Requirements	Verified
Implementation	Implemented
Testing	Verified
Acceptance Criteria	Verified
Existing CRUD	Verified
Final Status	Verified

6.1 Final Summary

CR-026 adds a password recovery feature to the Student Management System. The feature allows users to reset their password through an OTP sent to their registered email address. Validation and security controls are applied to OTP handling and password updates.

The implementation was completed, and all reported tests passed.

6.2 Issues / Limitations

No significant issues were identified during implementation and testing.

Student Name: M M Amal

Student ID: JF/ICT/24/15

Date: 15 October 2026

Signature: Amal